
Informe Profesional de Pentesting

Actividad A08 — Hacking Etico

Cliente: INSECUR S.A. — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Informacion — UCH

Docente: Ing. Rodrigo Atilio Elgueta

Federico Garcia

9 de octubre de 2026

Índice

1. Datos generales	2
2. Resumen ejecutivo	2
3. Pre-pentesting	3
4. Hallazgos — Basic Pentesting	3
5. Recomendaciones	11
6. Protocolo de contingencia	11
7. Anexos	12

1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno)	Federico Garcia
DNI	(omitido: repositorio publico)
Username TryHackMe	federico.garcia.uch
Sala obligatoria (Nivel 1)	Pentesting Fundamentals (metodologica) — completada
Sala obligatoria (Nivel 1)	Basic Pentesting — completada
Sala de eleccion (Nivel 2)	Vulniversity — pendiente
Objetivo Basic Pentesting	10.65.166.39 (SO Linux, Ubuntu 20.04)
Branch en GitHub	garcia-federico
Fecha de inicio	2026-10-08
Fecha de ejecucion (Basic)	2026-10-09
Estado	En curso (Basic completada; Vulniversity pendiente)

2. Resumen ejecutivo

Sintesis

Se desarrollo una evaluacion de pentesting de alcance acotado sobre los laboratorios autorizados de TryHackMe, en el marco de la actividad academica A08. **Pentesting Fundamentals** aporoto el marco metodologico (teorico). Sobre la maquina de **Basic Pentesting** (10.65.166.39) se completo el ciclo de intrusion de extremo a extremo: reconocimiento de servicios, enumeracion, acceso inicial, movimiento lateral y escalada de privilegios hasta obtener control total (root).

El hallazgo de mayor severidad es la combinacion de una **clave SSH privada legible por otros usuarios** y una **cuenta con privilegios sudo sin restriccion**, que en conjunto permiten pasar de un usuario sin privilegios a **root**. Dicho de otro modo: a partir de una contrasena SSH debil, un atacante obtiene una cuenta local y, encadenando malas configuraciones, logra el compromiso completo del host. Las recomendaciones centrales son corregir los permisos de las claves privadas, restringir **sudo** al minimo necesario y reforzar la politica de contrasenas.

La sala de eleccion Vulniversity queda pendiente de ejecucion; sus hallazgos y el Anexo de hashes de flags se incorporaran en la version final de este informe.

3. Pre-pentesting

Alcance

Maquinas de laboratorio que TryHackMe asigna para **Basic Pentesting** y **Vulniversity**, accesibles por la IP que la plataforma entrega via VPN. **Pentesting Fundamentals** se incluye como formacion metodologica (teorica, sin maquina, no genera hallazgos tecnicos). Fuera de alcance: todo sistema real o cualquier IP no asignada por la plataforma.

Reglas de Enfrentamiento (ROE)

Solo la IP asignada por TryHackMe via VPN (para Basic Pentesting: 10.65.166.39). Sin ataques de denegacion de servicio. Sin salir del alcance. Las pruebas de fuerza bruta se limitaron a un unico objetivo y usuario, con la wordlist estandar del laboratorio. *Ventanas horarias y limites de trafico: a confirmar con el docente.*

Autorizacion

Autorizacion de la catedra para A08 sobre los entornos de TryHackMe indicados en la guia. Las maquinas son de practica, intencionalmente vulnerables y provistas por la plataforma. No habilita acciones sobre sistemas reales ni de terceros.

Metodologia

NIST SP 800-115: sus cuatro fases (planificacion, descubrimiento, ataque y reporte) mapean con la estructura de este informe. La fase de ataque se documenta distinguiendo explicitamente: *servicio descubierto*, *vulnerabilidad demostrada*, *acceso obtenido* y *escalada de privilegios*. Para la parte web se usa OWASP WSTG como referencia.

Autenticidad de la evidencia

Username THM (federico.garcia.uch) visible en las capturas; evidencia organizada por fase en **evidencias/**; bitacoras de comandos en **bitacora/**; hash SHA-256 de flags en Anexo C; commits con identidad real en la rama **garcia-federico**. Las credenciales obtenidas (contrasenas, passphrase, clave privada) se tratan como material sensible y **no** se publican en el repositorio.

4. Hallazgos — Basic Pentesting

Objetivo: 10.65.166.39 (SO Linux, Ubuntu 20.04). **Herramientas:** nmap, smbclient, rpcclient, enum4linux, curl, hydra, ssh, ssh2john, john, ssh (cliente).

Servicios detectados (verificados con evidencia propia):

Puerto	Servicio	Version / Detalle
22/tcp	SSH	OpenSSH 8.2p1 Ubuntu (protocolo 2.0)
80/tcp	HTTP	Apache 2.4.41 (Ubuntu)
445/tcp	microsoft-ds (SMB)	Samba 4.15.13, SMB 3.1.1

Nota metodologica: se emplearon escaneos dirigidos a los puertos de interes (22, 80, 445). No se documentan aqui servicios adicionales que no cuenten con evidencia propia verificada en esta ejecucion.

H-01: Resolucion de nombres de usuario por SMB sin autenticacion

Campo	Valor
Fase	Enumeracion
Categoria del resultado	Vulnerabilidad demostrada (divulgacion de informacion)
Descripcion	El servicio SMB (445) admite una sesion nula (sin credenciales). Mediante <code>rpcclient</code> con el comando <code>lookupnames</code> se confirmo que <code>jan</code> y <code>kay</code> corresponden a cuentas de usuario validas (SID resueltos). <code>enum4linux</code> logro la sesion vacia pero no completo la enumeracion de usuarios, y <code>rpcclient enumdomusers</code> no devolvio resultados; por lo tanto no se afirma una enumeracion completa del dominio, solo la resolucion dirigida de nombres concretos.
Componente	Samba / SMB (puerto 445)
Categoria	CWE-200 (Exposure of Sensitive Information)
Herramienta	<code>rpcclient -U " " -N (lookupnames)</code> ; <code>enum4linux</code>
Impacto CIA	Confidencialidad (nombres de usuario validos facilitan ataques dirigidos de credenciales).
Salvaguarda	Restringir el acceso anonimo a SMB (<code>restrict anonymous = 2 / map to guest = Never</code> en <code>smb.conf</code>); limitar el puerto 445 por firewall a redes de confianza; deshabilitar SMB si el host no comparte archivos.
Riesgo residual	Bajo (tras restringir la sesion nula).
Evidencia	<code>evidencias/escaneo/bp_rpc_nombres.png</code> ; <code>bitacoras</code> <code>bp_rpc_nombres.txt</code> , <code>bp_smb_usuarios.txt</code> .

H-02: SMB con firma de mensajes no obligatoria

Campo	Valor
Fase	Escaneo
Categoria del resultado	Debilidad de configuracion (no se demostro explotacion)

Descripcion	El script <code>smb2-security-mode</code> de nmap reporta “Message signing enabled but not required” sobre SMB 3.1.1. La firma esta disponible pero el servidor no la exige, lo que constituye una debilidad de configuracion que podria habilitar ataques de tipo man-in-the-middle / relay. No se realizo ni se demostro un ataque de relay en esta evaluacion.	
Componente	Samba / SMB (puerto 445)	
Categoria	CWE-300 (Channel Accessible by Non-Endpoint)	
Herramienta	nmap -p445 --script smb2-security-mode	
Impacto CIA	Integridad y Confidencialidad (potencial, no demostrado).	
Salvaguada	Exigir firma SMB (<code>server signing = mandatory</code>); segmentar la red para reducir la exposicion a relay.	
Riesgo residual	Bajo.	
Evidencia	<code>evidencias/escaneo/bp_smb_signing.png;</code> <code>bp_smb_signing.txt.</code>	bitacora

H-03: Directorio web con listado y notas internas expuestas

Campo	Valor
Fase	Escaneo / Enumeracion
Categoria del resultado	Vulnerabilidad demostrada (divulgacion de informacion)
Descripcion	El directorio <code>/development/</code> (puerto 80) responde HTTP 200 con listado de directorio habilitado, exponiendo <code>dev.txt</code> y <code>j.txt</code> sin autentificacion. <code>dev.txt</code> contiene notas internas (menciones a Apache, configuracion de SMB y una referencia a Apache Struts 2.5.12). <code>j.txt</code> es una nota entre miembros del equipo indicando que una contrasena era debil y debia cambiarse. Aclaracion: la mencion a Struts 2.5.12 es una referencia en una nota de texto; no se verifico que ese componente este desplegado ni es explotable, por lo que no se asigna CVE.
Componente	Apache 2.4.41 (puerto 80)
Categoria	CWE-548 (Information Exposure Through Directory Listing)
Herramienta	curl (listado y descarga de <code>dev.txt</code> / <code>j.txt</code>)

Impacto CIA	Confidencialidad (exposicion de informacion interna y pistas de credenciales debiles).
Salvaguarda	Deshabilitar el listado de directorios (Options -Indexes); remover o proteger con autenticacion los directorios de desarrollo en produccion; revisar permisos de los recursos publicados.
Riesgo residual	Bajo-Medio.
Evidencia	bitacoras bp_development.txt , bp_dev.txt , bp-j.txt .

H-04: Acceso anonimo a recurso compartido SMB y fuga de informacion

Campo	Valor
Fase	Enumeracion / Acceso a datos
Categoria del resultado	Vulnerabilidad demostrada (acceso no autenticado + divulgacion)
Descripcion	El servidor expone un recurso compartido Anonymous accesible sin credenciales. Se accedio y se descargo staff.txt , un aviso interno al personal que menciona nominalmente a Jan y Kay , confirmando la existencia de esas cuentas y relacionando usuarios.
Componente	Samba / SMB (recurso Anonymous)
Categoria	CWE-306 (Missing Authentication for Critical Function)
Herramienta	smbclient (-L, ls, get)
Impacto CIA	Confidencialidad (acceso no autenticado a archivos y divulgacion de informacion interna).
Salvaguarda	Eliminar el recurso Anonymous o exigir autenticacion; aplicar valid users y permisos minimos; no almacenar informacion interna en shares de acceso publico.
Riesgo residual	Bajo (tras exigir autenticacion).
Evidencia	evidencias/escaneo/bp_smb_anonymous.png; bitacoras bp_smb_recursos.txt , bp_smb_anonymous.txt , bp_smb_descarga.txt , bp_staff.txt .

H-05: Contraseña SSH debil del usuario jan (fuerza bruta)

Campo	Valor
Fase	Explotacion
Categoria del resultado	Vulnerabilidad demostrada (credencial debil)
Descripcion	Siguiendo la pista de <code>j.txt</code> (H-03), se realizo una prueba de diccionario autorizada contra la cuenta <code>jan</code> por SSH usando la wordlist <code>rockyou.txt</code> . La prueba encontro un unico par valido de credenciales. El servicio no presenta mecanismo de bloqueo tras intentos fallidos. La contraseña no se incluye en el informe ni en el repositorio publico.
Componente	OpenSSH 8.2p1 (puerto 22) + politica de contraseñas
Categoria	CWE-521 (Weak Password Requirements); CWE-307 (No restriccion de intentos)
Herramienta	<code>hydra -l jan -P rockyou.txt ssh://</code>
Impacto CIA	Confidencialidad e Integridad (habilita acceso remoto autenticado).
Salvaguarda	Politica de contraseñas robusta; autenticacion por clave publica y deshabilitar password auth en SSH; mecanismos de bloqueo/retardo (fail2ban) ante intentos fallidos.
Riesgo residual	Medio (mientras persista password auth con contraseñas debiles).
Evidencia	<i>Privada</i> (muestra la contraseña): bitacora <code>bp_hydra.txt</code> y captura <code>evidencia_hydra.png</code> conservadas fuera del repositorio publico.

H-06: Acceso inicial obtenido como jan

Campo	Valor
Fase	Explotacion
Categoria del resultado	Acceso obtenido (usuario sin privilegios)
Descripcion	Con la credencial de H-05 se inicio sesion por SSH como <code>jan</code> , obteniendo una shell interactiva en el objetivo. Se verifico la identidad con <code>id (uid=1001(jan))</code> , <code>hostname (ip-10-65-166-39)</code> y <code>date</code> . La cuenta no pertenece al grupo <code>sudo</code> .

Componente	OpenSSH / sistema operativo
Categoria	Consecuencia directa de H-05
Herramienta	ssh (cliente)
Impacto CIA	Confidencialidad e Integridad (acceso valido al sistema como usuario local).
Salvaguarda	Las mismas de H-05 (clave publica, bloqueo de intentos, politica de contraseñas).
Riesgo residual	Medio.
Evidencia	evidencias/explotacion/bp_ssh_acceso.png; bitacora bp_ssh_acceso.txt.

H-07: Clave SSH privada legible por otros usuarios (movimiento lateral jan a kay)

Campo	Valor
Fase	Post-explotacion / Movimiento lateral
Categoria del resultado	Vulnerabilidad demostrada + acceso obtenido (segundo usuario)
Descripcion	Desde la shell de jan se observo que /home/kay/.ssh/id_rsa tiene permisos -rw-r--r-- (legible por cualquier usuario). Una clave privada nunca deberia ser legible por terceros (deberia ser 600). Se copio la clave y, tras recuperar su passphrase (H-08), se inicio sesion por SSH como kay, logrando el movimiento lateral a una segunda cuenta.
Componente	Permisos de archivo / OpenSSH
Categoria	CWE-732 (Incorrect Permission Assignment for Critical Resource)
Herramienta	ls -la; scp; ssh -i
Impacto CIA	Confidencialidad e Integridad (suplantacion de un segundo usuario del sistema).
Salvaguarda	Permisos 600 (propietario) en claves privadas; auditoria periodica de permisos en ~/.ssh; proteger las claves con passphrase robusta.
Riesgo residual	Alto hasta corregir permisos.

Evidencia	<code>evidencias/explotacion/bp_scp_clave.png</code> , <code>evidencias/explotacion/bp_kay_login.png</code> . <i>La clave privada en si se conserva fuera del repositorio publico.</i>
-----------	---

H-08: Passphrase debil en la clave SSH privada

Campo	Valor
Fase	Explotacion (offline)
Categoria del resultado	Vulnerabilidad demostrada (secreto debil)
Descripcion	La clave privada de kay estaba cifrada con una passphrase. Convertida a formato atacable con ssh2john , se recupero la passphrase con john y la wordlist rockyou.txt en menos de un segundo, lo que evidencia una passphrase trivial. El valor de la passphrase no se incluye en el repositorio publico.
Componente	Clave SSH privada de kay
Categoria	CWE-521 (Weak Password/Passphrase Requirements)
Herramienta	<code>ssh2john</code> ; <code>john --wordlist=rockyou.txt</code>
Impacto CIA	Confidencialidad (una passphrase debil no protege la clave si esta es legible — ver H-07).
Salvaguarda	Passphrase robusta en toda clave privada; rotacion de claves comprometidas; el control de permisos (H-07) es la defensa primaria.
Riesgo residual	Medio.
Evidencia	<i>Privada</i> (muestra la passphrase): captura <code>bp_john_passphrase.png</code> conservada fuera del repositorio publico.

H-09: Credencial almacenada en texto plano

Campo	Valor
Fase	Post-explotacion

Categoría del resultado	Vulnerabilidad demostrada (almacenamiento inseguro de credenciales)
Descripción	En el directorio home de kay existe el archivo pass.bak , que almacena una contraseña en texto plano. Como kay , se accedí a su contenido. El valor no se transcribe en el informe ni se publica en el repositorio.
Componente	Sistema de archivos / práctica del usuario
Categoría	CWE-312 (Cleartext Storage of Sensitive Information)
Herramienta	cat
Impacto CIA	Confidencialidad (exposición directa de una credencial válida).
Salvaguarda	No almacenar contraseñas en archivos de texto; usar gestores de secretos; eliminar backups de credenciales; concientización de usuarios.
Riesgo residual	Medio.
Evidencia	Documentado en texto; el valor se omite deliberadamente.

H-10: Privilegios sudo sin restriccion (escalada a root)

Campo	Valor
Fase	Escalada de privilegios
Categoría del resultado	Escalada de privilegios (compromiso total)
Descripción	sudo -l para kay devuelve (ALL : ALL) ALL: la cuenta puede ejecutar cualquier comando como root . Se ejecuto sudo -i y se obtuvo una shell con uid=0(root) , confirmando el compromiso completo del sistema.
Componente	Configuración de sudo (/etc/sudoers)
Categoría	CWE-269 (Improper Privilege Management)
Herramienta	sudo -l; sudo -i; id
Impacto CIA	Confidencialidad, Integridad y Disponibilidad (control administrativo total del host).

Salvaguarda	Aplicar minimo privilegio en sudoers: otorgar solo los comandos estrictamente necesarios; evitar (ALL:ALL) ALL; registrar y auditar el uso de sudo.
Riesgo residual	Alto hasta restringir sudoers.
Evidencia	evidencias/post/bp_sudo_l_y_bp_root.png.

Cadena de ataque (resumen)

Recon (SMB, HTTP, SSH) a **H-01/H-03/H-04** divulgacion de usuarios y notas internas a **H-05** contraseña SSH debil de **jan** a **H-06** acceso inicial como **jan** a **H-07/H-08** clave privada de **kay** legible + passphrase debil a movimiento lateral a **kay** a **H-09** credencial en texto plano a **H-10** **sudo** (ALL:ALL) a **root**. El impacto agregado de la cadena es **compromiso total del sistema (Critico)**, aunque cada hallazgo individual tiene la severidad indicada en su ficha.

Fases pendientes

*Sala de eleccion **Vulniversity**: pendiente de ejecucion. Sus hallazgos, evidencias y los hashes de flags correspondientes se incorporaran en la version final del informe.*

5. Recomendaciones

Tecnicas

Corregir permisos de claves privadas a 600 (H-07); restringir **sudo** al minimo necesario, evitando (ALL:ALL) ALL (H-10); eliminar credenciales en texto plano y backups de contraseñas (H-09); reforzar la politica de contraseñas y passphrases y preferir autenticacion por clave publica, deshabilitando password auth en SSH (H-05, H-08); restringir la sesion nula y exigir firma en SMB, y eliminar o autenticar el recurso Anonymous (H-01, H-02, H-04); deshabilitar el listado de directorios y proteger **/development/** (H-03); limitar por firewall los puertos expuestos a redes de confianza; mantener actualizados Apache, OpenSSH y Samba.

Administrativas

Politica de gestion de parches; revision periodica de servicios expuestos y de permisos en directorios sensibles; principio de minima exposicion (cerrar servicios no utilizados) y minimo privilegio; concientizacion de usuarios sobre manejo de credenciales.

6. Protocolo de contingencia

Escenario y RTO/RPO

*A completar: escenario de interrupcion de servicio, deteccion, contencion, recuperacion, comunicacion. RTO:
RPO:*

7. Anexos

Anexo A — Bitacora

Salidas de comandos en `bitacora/` (prefijo `bp_` para Basic Pentesting): conectividad, escaneos `nmap`, enumeracion `SMB/rpc`, acceso web, acceso `SSH`, movimiento lateral y escalada. Las bitacoras que contienen secretos (p.ej. la salida de `hydra`) se conservan fuera del repositorio publico.

Anexo B — Capturas

En evidencias/:

- `escaneo/bp_smb_signing.png` — firma `SMB` no obligatoria (H-02).
- `escaneo/bp_rpc_nombres.png` — resolucion de usuarios `jan/kay` (H-01).
- `escaneo/bp_smb_anonymous.png` — acceso anonimo a `SMB` y `staff.txt` (H-04).
- `explotacion/bp_ssh_acceso.png` — acceso inicial como `jan` (H-06).
- `explotacion/bp_scp_clave.png` — obtencion de la clave de `kay` (H-07).
- `explotacion/bp_kay_login.png` — login como `kay` (H-07).
- `post/bp_sudo_l_y_bp_root.png` — `sudo` (`ALL:ALL`) y shell root (H-10).
- `basic_pentesting_completada.png` — sala completada (usuario `federico.garcia.uch`).
- `fundamentals_completada.jpeg` — Pentesting Fundamentals completada.

Evidencias privadas (no publicadas por contener secretos): captura de `hydra` y de la `passphrase` recuperada con `john`.

Anexo C — Hashes de flags

```
# flag_id  sha256_hash
# (pendiente: se completara con las flags de Vulniversity)
```

Anexo D — Declaracion etica

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines academicos.

Firma

Fecha